CHAPTER 2

A SYSTEMATIC LITERATURE REVIEW

2.1 Introduction

The review does not only list technologies that can be applied to healthcare data sharing. It examines how existing approaches address different conditions required for a trustworthy authorisation decision and where conceptual or architectural gaps remain. Healthcare research has emphasised the importance of patient autonomy, privacy, informed consent, and controlled data sharing (Kaplow et al. 2024; Kharlamov, Hohmann & Parry 2023; McClelland & Harper 2023; Narkhede, Wankhede & Kamble 2025; Webber et al. 2019). Multi-party trust research has investigated immutable data governance, distributed auditability, and decentralised consent management (Andrew et al. 2023; Arbabi et al. 2023; Ghosh et al. 2023; Nguyen et al. 2025; Turan, Hashimzai & Qiam 2025). Research on decentralised identity and verifiable credentials has developed mechanisms for self-controlled identity representation, credential verification, selective disclosure, and privacy-preserving authentication (Deng et al. 2024; Flamini et al. 2024; Mazzocca et al. 2025; Nassar Kyriakidou, Papathanasiou & Polyzos 2023; Parameswarath, Gope & Sikdar 2022; Yin et al. 2025). Access-control research has further investigated role-based, attribute-based, risk-aware, and usage-control approaches for protecting sensitive healthcare information (Jiang et al. 2023; Nazir et al. 2026; Tawfik et al. 2025; Yin et al. 2024). However, the literature also indicates that these mechanisms are commonly developed and evaluated as separate technological components. Having the security mechanisms is one thing. Combining them into one trustworthy authorisation decision is another.

The structure of this chapter is as follows. Section 2.2 presents the six key requirements that a trustworthy multi-party consent authorisation should satisfy and that serve as the basis of the comparison. In Section 2.3, the process adopted for shortlisting the papers chosen for this SLR is discussed, including the criteria for searching the literature, the inclusion and exclusion criteria and the quality evaluation. Section 2.4 presents a summary of all the papers that were shortlisted, 25 in all, in six streams, and states the research gaps from the requirement perspective. In Section 2.5, the trust-oriented multi-party consent authorisation framework proposed in this thesis is positioned against the requirements. Finally, Section 2.6 concludes the SLR.

2.2 Key Requirements for Trustworthy Multi-Party Consent Authorisation

Trustworthy access should be understood as an outcome of the coordinated satisfaction of multiple independently verifiable conditions. The six requirements below collectively establish a progression from consent modelling and participant trust to collective authorisation, policy enforcement, temporal and lifecycle control, and finally formal security assurance and empirical validation. Each matches one sub-research question (Chapter 3), and each sub-research question addresses a distinct dimension of the proposed trust-oriented healthcare authorisation framework.

2.2.1 Req 1: Representation of consent as an evaluable authorisation object

- Rather than representing consent as a simple association between a patient, a requester, and a permission, consent should be represented as a structured and evaluable authorisation object. The object should incorporate identity information, authority requirements, policy constraints on purpose and data scope, temporal validity, lifecycle state, and authorisation evidence so that a consent decision can be evaluated when a subsequent data-access request is made.

2.2.2 Req 2: Decentralised verification of identity and authority

- Decentralised Identifiers (DIDs) and Verifiable Credentials (VCs) provide an alternative to conventional identity architectures based exclusively on centralised identity providers. Participants should establish persistent and cryptographically verifiable identifiers without dependence on a single identity provider. Identity verification establishes who is participating, while authority verification determines whether that entity satisfies the requirements associated with a particular consent. This separation prevents successful authentication from being interpreted as automatic authorisation.

2.2.3 Req 3: Multi-party authorisation through a verifiable threshold

- Multiple independently verified participants can jointly establish a trustworthy consent decision without allowing a single participant to unilaterally authorise sensitive healthcare data access. A predefined threshold of independent approvals from designated parties should be modelled as an explicit and independently verifiable security condition within the consent object.

2.2.4 Req 4: Policy- and context-aware enforcement at the time of access

- A requester may possess a valid identity, valid credentials, and even the required multi-party approval while still requesting information outside the scope authorised by the patient. The access decision must also be evaluated against the purpose and data-scope constraints explicitly associated with the consent. This applies to every request, because many unauthorised disclosures are caused by legitimate requesters who exceed their scope (Jiang et al. 2023).

2.2.5 Req 5: Temporal validity and lifecycle control of consent

- A consent that has expired, has been revoked, or has entered an invalid state must not be treated as an active authorisation even when its original identity, authority, and approval conditions were valid. The requirement is to ensure that an authorisation remains valid only within its permitted time interval and lifecycle state, and that expiration, immediate and verifiable revocation, and unauthorised state transitions are correctly enforced at every request.

2.2.6 Req 6: Verifiable auditability and security assurance

- A system may execute valid authorisation scenarios without demonstrating that invalid identities, insufficient approvals, or policy violations cannot produce an unintended access decision. Every decision should preserve verifiable evidence to explain the reason for that decision. Formal analysis or systematic adversarial testing should provide a complementary layer through which the expected security properties of the authorisation model can be explicitly defined and examined.

2.3 Process Adopted for Shortlisting the Papers for SLR

This section details the process adopted to identify the relevant papers to be reviewed in the SLR. A four-step process was adopted:

Step 1: Searching the literature. This step involves defining the search terms, identifying the data sources and the process of data collection.

Step 2: Inclusion and exclusion criteria. Criteria are defined to guide the selection of the most relevant studies.

Step 3: Quality evaluation. Each of the full-text studies is reviewed against six quality evaluation questions, one for each key requirement.

Step 4: Data analysis. After reviewing the selected studies, data are extracted, recorded and categorised into streams.

The review process was structured according to the Preferred Reporting Items for Systematic Reviews and Meta-Analyses (PRISMA) 2020 statement (Page et al. 2021). PRISMA was adopted to improve the transparency, reproducibility, and traceability of the literature identification and selection process. A written protocol (Protocol v1.1) fixed the review questions, databases, master query, eligibility criteria, codebook, and quality items before screening. All screening, coding, and quality assessment were carried out by the author. The review is guided by the six key requirements of Section 2.2, and the six quality evaluation questions of Step 3 are derived from them, one for each requirement.

2.3.1 Step 1: Criteria for Searching the Literature

This step involved deciding the databases to search, the search string, the information required from each record and the publication period of the records.

The literature search was conducted using the following academic databases including 1) IEEE Xplore, 2) ACM Digital Library, 3) ScienceDirect, 4) SpringerLink, 5) ProQuest Science and Technology, 6) Scopus, and 7) Web of Science. These databases were selected because they provide complementary coverage of computer science, cybersecurity, healthcare informatics, distributed systems, and information management research. ScienceDirect and SpringerLink were used to identify research on healthcare information systems, privacy, interoperability, and data governance. Scopus and Web of Science were used to improve the coverage of multidisciplinary studies. One master query of three concept blocks joined by AND covered healthcare data, consent and authorisation, and trust and multi-party concepts. The search string was ("Healthcare" OR "Health Data" OR "Medical Records") AND ("Consent" OR "Authorisation" OR "Authorization") AND ("Trust" OR "Multi-party" OR "Multi-party Approval"). The search strings were constructed using Boolean operators and were adapted only to the syntax requirements of each database.

Table 2.1 shows the seven databases and the number of records retrieved from each.

Table 2.1: Databases searched and records retrieved

S/N	Database	Records
1	SpringerLink	46
2	Scopus	38
3	IEEE Xplore	27
4	ProQuest Science and Technology	24
5	Web of Science	19
6	ScienceDirect	14
7	ACM Digital Library	11
	Total	179

2.3.2 Step 2: Inclusion and Exclusion Criteria

Not all the records identified in the previous step are considered in the SLR. They were further shortlisted according to the following inclusion and exclusion criteria.

The search results from all databases were exported into a reference management system. Duplicate records were identified using bibliographic metadata, including title, author, DOI, and publication year. Where duplicate records were identified, the most complete bibliographic record was retained for subsequent screening. Each study is cited by the year of the journal issue or proceedings volume in which it appeared, not the year it was first published online.

The eligibility criteria were defined before the screening process to ensure consistency in the selection of studies. Inclusion required healthcare data (IC1), consent, authorisation, access control, trust, or governance relevant to data access (IC2), and a mechanism, model, system, or evaluation relevant to a review question (IC3). Studies also had to be peer-reviewed English papers with full text (IC4 to IC7). The search was restricted to studies published between 2020 and 2026. The exclusion criteria removed, among others, studies outside healthcare or the authorisation scope, studies of authentication alone or with only a superficial mention of consent, non-peer-reviewed work, duplicate publications, and secondary reviews, although no study was excluded for failing to support the proposed research gap. Where a study addressed multiple topics, its eligibility was determined according to the relevance of its contribution to the review questions rather than by the presence of a single keyword.

Inclusion criteria:

1. Healthcare data sharing (IC1).

2. Consent or authorisation relevant to data access (IC2).

3. A model, mechanism, system or evaluation that addresses a review question (IC3).

4. Peer-reviewed English paper with full text (IC4 to IC7).

5. Publication between 2020 and 2026.

Exclusion criteria:

1. Outside healthcare or the authorisation scope.

2. Authentication alone or a superficial mention of consent.

3. Non-peer-reviewed work and duplicate publications.

The stages of evaluating and selecting the relevant papers for the SLR are summarised in Table 2.2.

Table 2.2: Summary of the stages of evaluating and selecting the relevant papers for the SLR

Evaluation stage	Method	Assessment criteria	Records
1st	Identify the related studies from the seven databases	Match the search string	179 identified
2nd	Remove duplicate records	Same title, author, DOI and publication year	21 removed, 158 remain
3rd	Screen the titles	Within healthcare consent or authorisation; otherwise exclude	76 excluded, 82 remain
4th	Screen the abstracts	Relevant to a review question; otherwise exclude	43 excluded, 39 remain
5th	Assess the full texts	Eligibility criteria and the quality evaluation of Step 3	14 excluded, 25 included

Figure 2.1 presents the PRISMA flow diagram for this review, which summarises the identification, screening, eligibility, and inclusion stages of the SLR. The seven database

searches returned 179 records: 46 from SpringerLink, 38 from Scopus, 27 from IEEE Xplore, 24 from ProQuest, 19 from Web of Science, 14 from ScienceDirect, and 11 from the ACM Digital Library. After 21 duplicates were removed, 158 records were screened by title, and 76 were excluded. The abstracts of the remaining 82 records were screened, and 43 were excluded. The full texts of 39 studies were then assessed for eligibility, 14 were excluded, and 25 studies were included in the analysis.

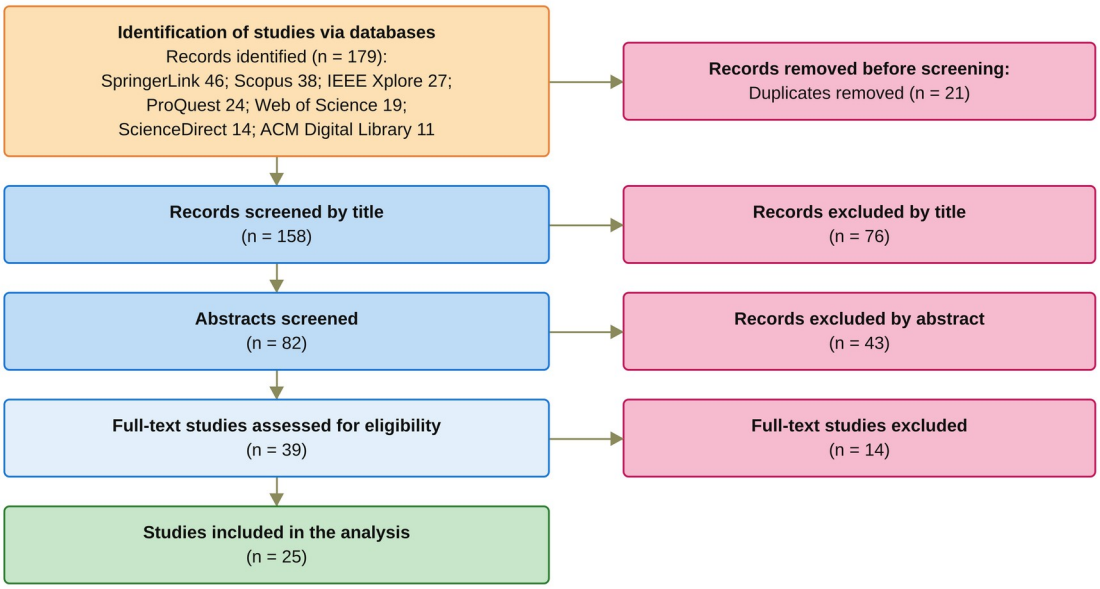


Figure 2.1: PRISMA 2020 flow diagram of the study identification, screening, eligibility and inclusion stages.

2.3.3 Step 3: Quality Evaluation

The 39 full-text studies were retrieved and critically evaluated based on the six quality evaluation questions, one for each key requirement of Section 2.2, as follows:

QA1: Does the study define a consent model covering identity, authority, policy, and evidence?

QA2: Does the study verify participant identities and their authorisation authority?

QA3: Does the study support consent decisions requiring approval from multiple authorised participants?

QA4: Does the study enforce purpose, data scope, and approval rules before allowing access?

QA5: Does the study manage consent validity, expiry, and revocation?

QA6: Does the study validate security and access decisions through formal analysis or implementation testing?

Each question was answered Yes or No, and any study which has at least three Yes answers to the six questions, and meets the eligibility criteria of Step 2, is included in this SLR. Of the 39 full-text studies, 25 satisfied the criteria, as shown in Table 2.3. Each included study was then coded Yes or No against each of the six requirements, Req 1 to Req 6, with a page reference for every Yes. A study is core if its gap-impact verdict is contradicts, weakens or narrows, or if it provides a multi-party approval mechanism. Of the 25 included studies, S1 to S25, 23 are core studies and 2 are supporting studies (Albalwy, Brass & Davies 2021; Li et al. 2026a).

2.3.4 Step 4: Shortlisted Papers for SLR and Categorising Them into Broad Areas

Each of the shortlisted papers was analysed according to its scope, topic and contribution to the review questions. Based on the analysis, each study was placed in one of six streams, one per requirement: consent representation (Req 1), identity and authority (Req 2), multi-party authorisation (Req 3), policy and context (Req 4), temporal and lifecycle (Req 5) and security assurance (Req 6). Table 2.3 lists the 25 primary studies with their authors, year and title. The papers in each stream are summarised in the next section, and their issues and limitations with respect to the key requirements defined in Section 2.2 are discussed.

Table 2.3: Listing of the 25 primary studies identified after the selection process

Study	Authors and year	Article title
S1	Abbasi et al. (2026)	Nexa: Enabling Secure, Scalable, and Decentralized Management of Electronic Health Records Using Threshold Cryptography and Public Blockchains
S2	Albalwy et al. (2021)	A Blockchain-based dynamic consent architecture to support clinical genomic data sharing (ConsentChain): Proof-of-concept study
S3	Al Amin et al. (2023)	Informed Consent as Patient Driven Policy for Clinical Diagnosis and Treatment: A Smart Contract Based Approach
S4	Ekholm et al. (2025)	Implementing electronic informed consent in rare disease genomics
S5	Eneh et al. (2026)	Demo: EdgeConsent: On-Chain Attribute-Based Access Control for Data Consent Management
S6	Hagström et al. (2024)	Minors' and guardian access to and use of a national patient portal: A retrospective comparative case study of Sweden and Finland
S7	Jaiman and Urovi (2020)	A Consent Model for Blockchain-Based Health Data Sharing Platforms
S8	Zhao and Su (2024)	A threshold traceable delegation authorization scheme for data sharing in healthcare
S9	Li et al. (2026a)	Privacy-Preserving Fine-Grained EMR Access Control for IoMT: A Hybrid RBAC-Smart Contract Scheme With Attribute-Based Authorization
S10	Madine et al. (2020)	Fully Decentralized Multi-Party Consent Management for Secure Sharing of Patient Health Records
S11	Maruthi and Singh (2025)	Enhancing Security and Privacy of IoMT Data for Unconscious Patient With Blockchain
S12	Mei et al. (2026)	Efficient Dual-Revocation CP-ABE for Secure and Fine-Grained Data Sharing in IoMT
S13	Panagoulias et al. (2026)	Blockchain-Enabled Trust and Compliance for Clinical AI: Decentralized Governance Without Decentralized Data Storage
S14	Phuyal et al. (2026b)	Enabling Cross-Institution Health Data Sharing in Norway: EUDI Wallets, On-Chain Consent, and openEHR↔FHIR Translation
S15	Phuyal et al. (2026a)	A Blockchain-Based Architecture for Dynamic and Auditable Patient Consent in Secondary Use of Health Data
S16	Punia et al. (2025)	An access control system for cloud-based healthcare systems driven by blockchain
S17	Román-Martínez et al. (2023)	Blockchain-Based Service-Oriented Architecture for Consent Management, Access Control, and Auditing
S18	Hema et al. (2026)	Patient Centric Cryptographic Protection of Cloud Electronic Health Records
S19	SooHoo et al. (2026)	Development of the authentication and authorization processes for the iAgree portal, a platform for patient-controlled data sharing across health systems

Study	Authors and year	Article title
S20	Tan et al. (2024)	Secure and privacy-preserving sharing of personal health records with multi-party pre-authorization verification
S21	Tith et al. (2020)	Patient consent management by a purpose-based consent model for electronic health record based on blockchain technology
S22	Tremper et al. (2026)	Mainzelliste: Ten years of pseudonymization, record linkage, and informed consent management
S23	Tseng et al. (2025)	EMR-Chain: Decentralized Electronic Medical Record Exchange System
S24	Wu et al. (2022)	Apply Trust Computing and Privacy Preserving Smart Contracts to Manage, Share, and Analyze Multi-site Clinical Trial Data
S25	Wu and Zhang (2025)	HealthDID: An efficient and authorizable multi-party privacy-preserving EMR sharing system based on DID

2.4 Summary of Papers Shortlisted in the SLR

The extracted data were organised into thematic categories corresponding to the research questions. Each included study was assigned to one stream, normally the one on which it is coded most strongly. S6 (Hagström et al. 2024) is placed in the multi-party stream for its guardian access gate, although it is not graded Yes on Req 3.

2.4.1 Consent representation and blockchain-based consent governance (Req 1)

Two of the three studies of this stream are deployed platforms that do not fully satisfy Req 1. SooHoo et al. (2026) describe the iAgree portal across three United States health systems with a permissioned Ethereum audit contract, but consent enforcement is outside its scope. Tremper et al. (2026) report ten years of the Mainzelliste service with FHIR consent directives, but specify no check semantics and no demonstrated enforcement of withdrawal. The two platforms are single-party systems. Al Amin et al. (2023) model informed consent as a patient-driven policy object with hash integrity, but specify no purpose condition and report no measured results. The supporting references represent consent as a permission indicating whether a particular party is allowed to perform a specified operation (Akter & Sanam 2025; Prashanth et al. 2024), as conditions fixed at encryption time (Zhang, Kan & Huang 2022), or as a key issued by the patient for each request (Teeda & Subba Rao 2026). The existence of a consent record does not necessarily explain whether the conditions required for a subsequent access request are still satisfied. Table 2.4 summarises the description, the issues and limitations, and the requirement grades of the studies in this stream.

Table 2.4: Descriptions, issues and limitations of the studies on consent representation

Study	Description of the study	Issues/Limitations	Req 1	Req 2	Req 3	Req 4	Req 5	Req 6
S3 Al Amin et al. (2023)	Informed consent is modelled as a patient-driven policy object with hash integrity, which an authorisation module conjoins with other policies inside a smart contract.	Purpose is not a condition, the time and expiry conditions are specified but not enforced, the only multi-party element is a 2-of-2 co-signature at registration, and the Goerli evaluation reports no measured results.	Yes	No	No	No	No	No
S19 SooHoo et al. (2026)	The authentication and authorisation processes of the iAgree portal across three United States health systems, using OAuth2, SMART on FHIR, and one-time passwords, with a permissioned Ethereum audit contract.	Consent enforcement is outside its scope, a single patient decides, identity and authority are not separated, revocation is claimed but not tested, and there are no formal methods.	No	No	No	No	No	No

Study	Description of the study	Issues/Limitations	Req 1	Req 2	Req 3	Req 4	Req 5	Req 6
S22 Tremper et al. (2026)	Ten years of the Mainzelliste production service for pseudonymisation, record linkage, and informed consent management, with purpose-scoped FHIR consent directives and automated consent checks.	The consent checks have no specified semantics and no demonstrated enforcement of withdrawal, its multi-party computation parties are linkage units rather than authorisers, and no consent decision is verified.	No	No	No	No	No	No

2.4.2 Decentralised identity and authority trust (Req 2)

Req 2, which needs both identity and authority, is graded Yes in only 7 of the 25 studies in Table 2.10. Phuyal et al. (2026b) present the most integrated system, with EUDI-compatible wallets, W3C decentralised identifiers, verifiable credentials, an on-chain consent object on Hyperledger Besu, and Groth16 access proofs. Its licensing-body credential asserts role and scope of practice separately from authentication, which is among the strongest Req 2 evidence in the corpus. However, a single patient grants consent, the stored expiry is not checked, there is no threat model, and the companion architecture (Phuyal et al. 2026a) is design-only. Tseng et al. (2025) verify authority-issued roles separately from X.509 identities, although without W3C identifiers and with purpose logged but never evaluated. Neither identity verification nor credential possession automatically establishes that the participant should be granted access to a particular patient's information.

Table 2.5 summarises the description, the issues and limitations, and the requirement grades of the studies in this stream.

Table 2.5: Descriptions, issues and limitations of the studies on identity and authority

Study	Description of the study	Issues/Limitations	Req 1	Req 2	Req 3	Req 4	Req 5	Req 6
S14 Phuyal et al. (2026b)	Cross-institution health data sharing with EUDI-compatible wallets, W3C decentralised identifiers, verifiable credentials, an on-chain consent object on Hyperledger Besu, and Groth16 access proofs, where a licensing-body credential asserts role separately from authentication.	A single patient grants consent, the stored expiry is not checked, purpose is handled only at the interface, and there is no threat model.	Yes	Yes	No	No	No	Yes
S15 Phuyal et al. (2026a)	A design-science architecture for dynamic and auditable patient consent in secondary use, using FHIR Consent with purpose, scope, actors, and validity period, anchored on chain, with conceptual VC validation at a gateway.	The architecture is design-only and is neither implemented nor evaluated, and delegation through VCs is not joint multi-party approval.	No	No	No	No	No	No
S23 Tseng et al. (2025)	EMR-Chain, a decentralised electronic medical record exchange that verifies authority-issued roles separately from X.509 identities and enforces token expiry at the validator.	It has no W3C identifiers, purpose is logged but never evaluated, scope is hospital-level only, the patient and requester signatures authenticate the request rather than add an independent authoriser, and revocation does not invalidate issued tokens.	No	Yes	No	No	No	No

2.4.3 Multi-party authorisation and collaborative consent (Req 3)

Req 3 is graded Yes in 6 of the 25 studies and No in 19, across six mechanism classes. Madine et al. (2020) require a regulator and a guardian threshold on the incapacitated

path, but a single patient key suffices on the normal path. Wu et al. (2022) apply a (t, n) investigator threshold to record admission and revocation, and Abbasi et al. (2026) use a Shamir (5, 3) threshold for key custody. Punia et al. (2025) conjoin an M-of-N multi-signature with an attribute and role policy, but a single emergency officer can bypass the threshold. Tan et al. (2024) use patient-appointed verifiers as a contingency, (Ekholm et al. 2025) reports guardian co-consent at registration time, and (Hagström et al. 2024) gates guardian access by the minor's consent and a clinician's capacity assessment. No reviewed study evaluates a threshold predicate over a patient-designated guardian set on every request, and none does so together with the policy, temporal, and lifecycle conditions. Multi-party verification of identity should not be considered equivalent to multi-party authorisation of data access.

Table 2.6 summarises the description, the issues and limitations, and the requirement grades of the studies in this stream.

Table 2.6: Descriptions, issues and limitations of the studies on multi-party authorisation

Study	Description of the study	Issues/Limitations	Req 1	Req 2	Req 3	Req 4	Req 5	Req 6
S1 Abbasi et al. (2026)	Decentralised EHR management in which a Shamir (5, 3) threshold reconstructs a symmetric key, and automated oracles release their shares according to the requester's on-chain role.	The threshold is over key custodians rather than authorisers, the patient share is not required, purpose is not evaluated, and no authorisation decision is verified despite extensive performance measurement.	No	No	No	No	No	No
S4 Ekholm et al. (2025)	A deployed electronic informed consent platform for rare disease genomics, in which a minor's consent is valid only when all legal guardians sign, and guardianship is verified against the Swedish Population Register.	The guardian co-consent applies at registration rather than at each access request, the platform is centralised and described with little technical detail, and there is no temporal, purpose, or formal assurance condition.	No	Yes	Yes	No	No	No
S6 Hagström et al. (2024)	A comparative case study of national patient portals, in which a clinician's capacity assessment and the minor's consent jointly gate guardian access, with register-verified guardianship and enforced age windows.	The mechanism is centralised and applied at documentation time, and the guardian is the party whose proxy access is gated rather than a co-authoriser of the patient's access decision.	No	Yes	No	No	Yes	Yes
S10 Madine et al. (2020)	Fully decentralised multi-party consent management in which, on the incapacitated path, approvals from a regulator and a guardian threshold are required on one access request, and stale attestations stop counting.	On the normal path a single patient key authorises, so multi-party approval is a contingency. Purpose and data-category policy are absent, revocation after delivery is not possible, and there is no formal assurance.	Yes	Yes	Yes	No	Yes	No
S16 Punia et al. (2025)	MedXBlock, a blockchain-driven access control system for cloud healthcare that combines an institutional M-of-N multi-signature with a conjunctive role and attribute policy evaluated with deny-by-default.	The signers are doctors and administrators rather than patient-side parties, the threshold sits outside the decision predicate and a single emergency officer can bypass it, there is no purpose term, and no authorisation decision is verified.	No	No	Yes	Yes	Yes	No

Study	Description of the study	Issues/Limitations	Req 1	Req 2	Req 3	Req 4	Req 5	Req 6
S20 Tan et al. (2024)	Sharing of personal health records with multi-party pre-authorisation verification, in which a (t, n) threshold of patient-appointed verifiers each validate the grant, its expiry, and the revocation list before releasing a key share.	The joint approval is a pre-delegated contingency for an unconscious patient rather than a standing condition, purpose and data scope are not evaluated, and the gate is not evaluated empirically as an authorisation decision.	Yes	Yes	Yes	No	No	No
S24 Wu et al. (2022)	Trust computing and privacy-preserving smart contracts for multi-site clinical trial data, in which a (t, n) investigator threshold signature governs trial admission to the ledger and consent revocation.	The consent grant is unilateral, the voters are institution-side investigators, the vote reduces to a hash-integrity check, there is no policy engine, and there is no formal assurance.	No	No	No	No	No	No

2.4.4 Policy- and context-aware access control (Req 4)

Tith et al. (2020) match a purpose tree in chaincode, and Jaiman and Urovi (2020) match ontology terms against the patient's consent. Albalwy et al. (2021) evaluate a hashed policy tree of data type, role, and purpose, and Román-Martínez et al. (2023) evaluate the FHIR purpose-of-use through XACML. Req 4 is graded Yes in 10 studies and No in 15 in Table 2.10. However, purpose-of-use enters the decision in only six studies (Eneh et al. 2026; Panagoulias et al. 2026), and every one is graded No on Req 3. Consequently, purpose and data-scope constraints are not carried by the consent object C and evaluated together with the identity, authority, and multi-party conditions.

Table 2.7 summarises the description, the issues and limitations, and the requirement grades of the studies in this stream.

Table 2.7: Descriptions, issues and limitations of the studies on policy and context

Study	Description of the study	Issues/Limitations	Req 1	Req 2	Req 3	Req 4	Req 5	Req 6
S2 Albalwy et al. (2021)	A blockchain-based dynamic consent proof of concept for clinical genomic data, in which a hashed policy tree of data type, role, and purpose is evaluated by the smart contract.	A single patient sets and cancels consent, the requester's role and credentials are not verified, time is applied only at the delivery layer, and there is no formal assurance.	Yes	No	No	Yes	No	Yes
S7 Jaiman and Urovi (2020)	A consent model in which ontology terms requested by a data requester are matched against the patient's consent inside the smart contract, with denial tested across requester profiles.	Security assurance is explicitly outside its scope, and there is no multi-party approval.	Yes	No	No	Yes	No	Yes
S17 Román-Martínez et al. (2023)	A blockchain-based service-oriented architecture on Hyperledger Fabric for consent management, access control, and auditing, in which FHIR purpose-of-use limits are evaluated per resource through XACML.	There is no withdrawal or expiry path, and the experiments validate only the blockchain component.	Yes	No	No	Yes	No	No
S21 Tith et al. (2020)	A purpose-based consent model on Hyperledger Fabric, in which a consent tuple of role, doctor identifiers, action, and intended purpose is matched against a purpose tree in chaincode at request time.	Consent is given by a single patient, the tuple has no temporal element, the effect of withdrawal is not tested, identity uses Fabric certificates without DID or VC, and there is no formal verification.	Yes	No	No	Yes	No	No

2.4.5 Temporal validity and consent lifecycle (Req 5)

A consent that is valid at one point in time cannot necessarily be assumed to remain valid indefinitely. Eneh et al. (2026) present EdgeConsent, which enforces temporal validity inside the decision predicate, although its lifecycle is only an active flag. Temporal validity must also be evaluated together with the lifecycle state of the consent. Hema et al. (2026) bind the expiry into key derivation, and Panagoulias et al. (2026) enforce revocation at decision time across 43,500 simulated attempts in a single-node ledger. Req 5 is graded Yes in 8 studies, a post-revocation denial is demonstrated only by Phuyal et al. (2026b), which enforces revocation but not expiry, so it does not fully satisfy Req 5, and the four stream-5 systems that enforce time inside the decision are all single-party, with Li et al. (2026a) doing so through the credential rather than the consent.

Table 2.8 summarises the description, the issues and limitations, and the requirement grades of the studies in this stream.

Table 2.8: Descriptions, issues and limitations of the studies on temporal validity and lifecycle

Study	Description of the study	Issues/Limitations	Req 1	Req 2	Req 3	Req 4	Req 5	Req 6
S5 Eneh et al. (2026)	EdgeConsent, a demonstration of on-chain attribute-based access control in which consent rules with purpose, data category, and notBefore and notAfter bounds are evaluated at decision time.	A two-page demonstration with weak identity and authority trust and no DID or VC, no multi-party approval, a lifecycle that is only an active flag, and preliminary local evaluation without formal assurance.	Yes	No	No	Yes	Yes	No
S9 Li et al. (2026a)	A hybrid RBAC and smart contract scheme with attribute-based authentication for fine-grained EMR access in IoMT, which enforces credential expiry at every sharing interaction.	Time is enforced in the decision through the credential rather than the consent, which is why Req 5 is graded Yes, but the consent itself carries no enforced validity window, and there is no multi-party approval.	No	No	No	Yes	Yes	No
S13 Panagoulias et al. (2026)	Blockchain-enabled trust and compliance for clinical AI, in which an Allow predicate over time, revocation, role, and purpose is evaluated before execution and denials are recorded, verified across simulated attempts with zero consent drift.	A simulated single-node prototype with set-membership policy and aggregate deny attribution, without multi-party approval or identity depth, and the authors declare no formal assurance.	Yes	No	No	Yes	Yes	Yes
S18 Hema et al. (2026)	Patient-centric cryptographic protection of cloud EHRs, in which a signed consent token, role, and expiry are inputs to key derivation, so that access becomes a cryptographic precondition and role-scoped keys separate authority from identity.	Consent is issued from a single patient key, identity relies on a cloud authentication service without DID or VC, and assurance is limited to an adversary model.	Yes	No	No	Yes	Yes	No

2.4.6 Formal security assurance and empirical validation (Req 6)

Experimental success alone cannot establish that unauthorised access is impossible under the stated model, while formal reasoning establishes security properties only under explicitly defined assumptions. Consequently, the two forms of evidence are complementary rather than interchangeable. Wu and Zhang (2025) present HealthDID, with three game-based definitions and three theorems proved by reduction, although the proofs cover only the identity and authority fragment. Zhao and Su (2024) and Maruthi and Singh (2025) prove threshold gates in isolation, and Mei et al. (2026) prove a static encryption predicate. Req 6 is graded Yes in 9 of the 25 studies: formal assurance is provided by only 4 of them, and the other 5 rest on empirical validation. An inverse

relation between predicate breadth and assurance strength was observed. Few studies execute adversarial scenarios that examine whether security controls can resist deliberate attempts to circumvent the authorisation process.

Table 2.9 summarises the description, the issues and limitations, and the requirement grades of the studies in this stream.

Table 2.9: Descriptions, issues and limitations of the studies on security assurance

Study	Description of the study	Issues/Limitations	Req 1	Req 2	Req 3	Req 4	Req 5	Req 6
S8 Zhao and Su (2024)	A threshold traceable delegation scheme in which the patient delegates a threshold of l already-authorised users, who must jointly authorise an out-of-policy requester, with unforgeability argued under DBDH.	The authorisers are consumer-side delegates rather than patient-side stakeholders, the patient's own decision is unilateral, a trusted authority escrows keys, and there is no temporal, lifecycle, or purpose condition.	No	No	Yes	No	No	Yes
S11 Maruthi and Singh (2025)	Protection of IoMT data for unconscious patients, in which t-of-n patient-designated relatives release access through threshold proxy re-encryption, and the hospital and relatives are authenticated on chain.	Policy and temporal conditions are not evaluated, and the proofs cover the threshold gate in isolation rather than the complete decision.	No	No	Yes	No	No	Yes
S12 Mei et al. (2026)	An efficient dual-revocation CP-ABE scheme for IoMT that terminates access immediately through ciphertext update, motivated by consent withdrawal, with a security reduction under q-BDHE.	The proof covers a static encryption predicate, revocation operates at scheme level rather than on a consent object, and there is no multi-party approval.	No	No	No	Yes	Yes	Yes
S25 Wu and Zhang (2025)	HealthDID, a DID-based privacy-preserving EMR sharing system with three game-based definitions and three theorems proved by reduction, in which a zero-knowledge proof binds the authorisation to a specific requester.	The proofs cover only the identity and authority fragment, multi-party refers to the privacy requirements of several stakeholders rather than joint approval, and there are no policy, temporal, or lifecycle conditions.	Yes	Yes	No	No	No	Yes

2.4.7 Research Gaps in the Existing Studies from the Requirement Perspective

The systematic literature review indicates that substantial research has been conducted on individual mechanisms for securing healthcare data sharing, including blockchain-based consent management, decentralised identity, verifiable credentials, cryptographic access control, policy-based authorisation, and multi-party approval. These approaches have demonstrated the value of decentralisation, tamper-resistant records, verifiable identity, fine-grained access control, and distributed decision-making in addressing different aspects of healthcare data security. However, the literature also reveals a significant conceptual and architectural fragmentation among these mechanisms. They are commonly investigated as independent technical solutions rather than as coordinated components of a unified trust-oriented authorisation model.

The central gap is therefore not the absence of technologies for recording consent, verifying identity, or restricting data access. Rather, it is the absence of a sufficiently integrated model explaining how these mechanisms collectively establish a trustworthy authorisation decision. In particular, existing consent-oriented approaches tend to treat consent primarily as a record of a patient's permission. Once the permission has been created and stored, subsequent access control may depend predominantly on the existence of the consent record and the successful authentication of the requester. Such a model establishes evidence that a consent decision occurred, but it does not necessarily

establish that the requester possesses the required authority, that all required parties have independently approved the access, or that the requested operation is consistent with the purpose and data scope originally authorised by the patient, or that the consent is still valid in time and lifecycle state at the moment of the request.

This distinction is important because recording consent and enforcing trustworthy authorisation represent fundamentally different security problems. A blockchain may provide an immutable representation of a consent event, but immutability does not establish the legitimacy of the entities involved in that event. Similarly, a valid decentralised identity can establish who a participant is, but it does not necessarily establish what that participant is authorised to do. Multi-party approval can strengthen collective decision-making, but approval alone does not guarantee that the resulting access request conforms to the patient's authorised purpose or data scope. Consequently, trust cannot be attributed to any individual mechanism in isolation.

From a Trust Computing perspective, this leads to a more fundamental research problem. Trustworthy access should be understood as an outcome of the coordinated satisfaction of multiple independently verifiable conditions. The relevant conditions include the legitimacy of the participating identities, the authority associated with those identities, the satisfaction of required collective approval conditions, and compliance between the requested operation and the policy defined by the consent, and the temporal validity and lifecycle state of the consent at the time of the request. The research therefore conceptualises trust not as a static attribute possessed by a particular entity or technology, but as an emergent property of a verifiable authorisation process.

This perspective also introduces an important distinction between authentication, authorisation, and trustworthy access. Authentication determines whether an entity can be identified and verified. Authorisation determines whether the entity is permitted to perform a particular operation. Trustworthy access requires an additional consideration: whether the authorisation decision itself has been established through sufficient, verifiable, and policy-compliant conditions. The research consequently investigates how these layers can be connected within a single framework without reducing trust to any individual credential, transaction, or access-control rule.

The identified gap can therefore be stated as follows: existing healthcare consent and access-control research provides many of the necessary technological building blocks, but there remains a need for an integrated Trust Computing framework that treats patient consent as a security-bearing and evaluable authorisation object. Such a framework should be capable of representing the relevant trust conditions, verifying the participating entities and their authority, establishing collective authorisation where required, and enforcing the policy and data-scope constraints associated with the consent, and ensuring that the authorisation remains valid only within the time interval and lifecycle state of the consent. The research addresses this gap by developing a trust-oriented authorisation model in which consent is not simply evidence that permission was granted, but the basis for evaluating whether a particular access request should be trusted. The resulting research direction places Trust Computing at the centre of the investigation, while treating blockchain, decentralised identity, verifiable credentials, and policy mechanisms as enabling technologies supporting the broader trust model.

Existing approaches solve single dimensions of trustworthy data sharing, each at a different layer of the security problem. No individual mechanism can independently establish that a healthcare data-access decision is trustworthy. The systems that enforce purpose and time are authored by a single patient and lack a formal argument. The multi-party systems carry no purpose condition, whereas the proved schemes either omit policy, temporal validity, and lifecycle or, as in (Mei et al. 2026), prove only a static encryption predicate. Table 2.10 summarises the 25 studies against the six requirements, where Yes denotes that the requirement is fully satisfied and No that it is not fully

satisfied. In the Req 6 column each study takes the higher of its formal assurance grade and its empirical validation grade.

Table 2.10: Comparison of the included studies against the key requirements

Study	Req 1	Req 2	Req 3	Req 4	Req 5	Req 6
S1 Abbasi et al. (2026)	No	No	No	No	No	No
S2 Albalwy et al. (2021)	Yes	No	No	Yes	No	Yes
S3 Al Amin et al. (2023)	Yes	No	No	No	No	No
S4 Ekholm et al. (2025)	No	Yes	Yes	No	No	No
S5 Eneh et al. (2026)	Yes	No	No	Yes	Yes	No
S6 Hagström et al. (2024)	No	Yes	No	No	Yes	Yes
S7 Jaiman and Urovi (2020)	Yes	No	No	Yes	No	Yes
S8 Zhao and Su (2024)	No	No	Yes	No	No	Yes
S9 Li et al. (2026a)	No	No	No	Yes	Yes	No
S10 Madine et al. (2020)	Yes	Yes	Yes	No	Yes	No
S11 Maruthi and Singh (2025)	No	No	Yes	No	No	Yes
S12 Mei et al. (2026)	No	No	No	Yes	Yes	Yes
S13 Panagoulias et al. (2026)	Yes	No	No	Yes	Yes	Yes
S14 Phuyal et al. (2026b)	Yes	Yes	No	No	No	Yes
S15 Phuyal et al. (2026a)	No	No	No	No	No	No
S16 Punia et al. (2025)	No	No	Yes	Yes	Yes	No
S17 Román-Martínez et al. (2023)	Yes	No	No	Yes	No	No
S18 Hema et al. (2026)	Yes	No	No	Yes	Yes	No
S19 SooHoo et al. (2026)	No	No	No	No	No	No
S20 Tan et al. (2024)	Yes	Yes	Yes	No	No	No
S21 Tith et al. (2020)	Yes	No	No	Yes	No	No
S22 Tremper et al. (2026)	No	No	No	No	No	No
S23 Tseng et al. (2025)	No	Yes	No	No	No	No
S24 Wu et al. (2022)	No	No	No	No	No	No
S25 Wu and Zhang (2025)	Yes	Yes	No	No	No	Yes

The matrix supports four observations. First, counting only full satisfaction, Req 1 is met by 12 of the 25 studies, Req 2 by 7, Req 3 by 6, Req 4 by 10, Req 5 by 8, and Req 6 by 9. Second, no study satisfies all six, the maximum of four is reached by (Madine et al. 2020) and (Panagoulias et al. 2026), and five studies fully satisfy none. Third, Req 1 with Req 4 is the most frequent pair, in seven studies, whereas Req 2 and Req 4 never co-occur in full. Req 3 co-occurs with Req 4 only in (Punia et al. 2025), whose threshold lies outside the policy predicate and whose policy carries no purpose term. Similarly, Req 3 co-occurs with Req 6 only in (Maruthi & Singh 2025; Zhao & Su 2024). Fourth, the two quadruples are complementary, since Madine et al. (2020) lack full policy and assurance, whereas Panagoulias et al. (2026) lack multi-party approval and full identity depth.

The comparison shows that the contribution of this research is the explicit relationship it establishes among existing technologies, not their replacement. The consent object C carries the identity, authority, threshold, policy, temporal, and lifecycle conditions together, so that their relationship is verifiable. Section 2.5 positions the proposed framework relative to these requirements. The conjunction is formally specified and validated through allow-and-deny test cases and attack cases, whereas its formal

verification and the remaining lifecycle extensions of RQ5 are left for the next stage (Chapters 9 and 10).

The literature review identifies a consistent pattern of fragmentation across existing research. Across the corpus, Req 3 is the least satisfied requirement, while within Req 6, formal assurance alone is provided by 4 studies, argued informally by 9, and absent in 12. The other five Yes grades for Req 6 in Table 2.10 rest on empirical validation.

The review corrects one framing. Multi-party authorisation of patient consent is not absent from the literature, since the full-text coding shows it in six forms. These range from contingency-path joint approval and admission gates to delegated, witness, and custodial thresholds and guardian co-consent at registration, but no reviewed study treats it as a constitutive predicate that every access decision must satisfy together with the identity, policy, and temporal conditions. The gap is therefore not the absence of technologies for recording consent, verifying identity, or restricting data access. Rather, it is the absence of a sufficiently integrated model explaining how these mechanisms collectively establish a trustworthy authorisation decision.

The review establishes two gaps. The first is a **conjunction gap**, since no study conjoins identity, authority, threshold, policy, temporal, and lifecycle conditions in one decision predicate in which multi-party approval is a standing condition and the patient defines the approving set. The second is an **assurance gap**, since co-existing conditions are neither proved nor tested as an authorisation decision, and any proof covers only a fragment of the predicate. As shown in Figure 2.2, the proposed research addresses both gaps by developing a trusted multi-party consent governance framework in which consent is represented as an evaluable authorisation object. Each of Req 1 to Req 6 also leaves a requirement-level gap, termed Gap 1 to Gap 6 and stated in Chapter 3, and each gap corresponds to the research question and objective of the same number in Chapter 3.

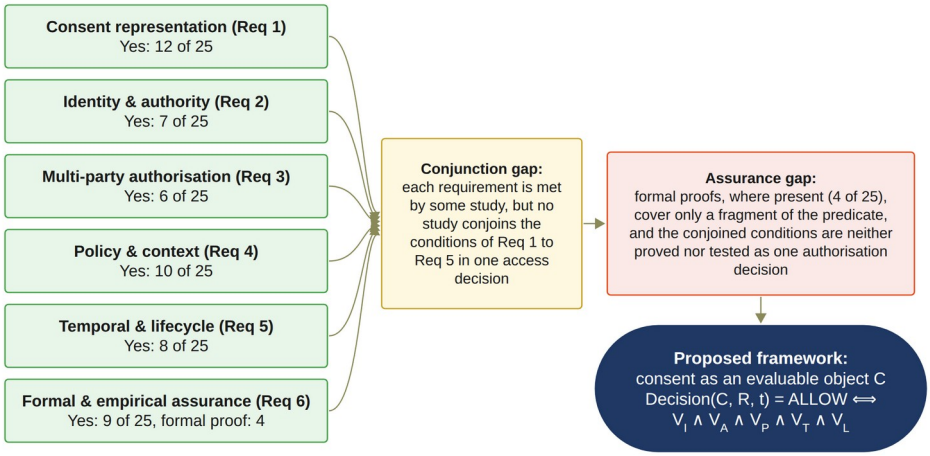


Figure 2.2: Synthesis of the review: the conjunction gap and the assurance gap addressed by the proposed framework, with the number of the 25 analysed studies graded Yes for each requirement in Table 2.10.

As presented in Tables 2.4 to 2.10, researchers have focused on securing individual aspects of healthcare data sharing: recording consent, verifying identity, approving access, and restricting the data that are released. However, from the perspective of the six requirements stated in Section 2.2, the existing work has the following drawbacks:

- *Inability to represent consent as an evaluable authorisation object (Req 1):* Existing consent approaches treat consent primarily as a record of a patient's permission (Akter & Sanam 2025; Prashanth et al. 2024), and some claim consent but leave it out of the access decision (Sawant & Gomes 2026). The evaluable consent objects reported since 2020 (Albalwy, Brass & Davies 2021; Eneh et al. 2026; Phuyal et al. 2026b; Shanmugham & Senthilkumar 2026; Tith et al. 2020) carry only a subset of

the identity, authority, threshold, policy, temporal and lifecycle conditions, and they are issued by a single party. Without such a representation, the existing literature does not allow an access request to be evaluated against the conditions that the patient actually set.

- *Inability to verify authority separately from identity (Req 2):* A valid decentralised identity establishes who a participant is (Mazzocca et al. 2025), but it does not establish what that participant is authorised to do. Authority is verified separately from authentication in only 10 of the 25 studies, and Req 2 is graded Yes in 7 of them (Table 2.10). Without this separation, an authenticated participant is treated as an authorised one.
- *Absence of multi-party approval as a standing condition of every access decision (Req 3):* Multi-party approval appears in the reviewed studies as a contingency path, an admission gate or a registration-time co-consent (Madine et al. 2020; Punia et al. 2025; Tan, Chi & Lam 2024). The approving set is defined on the institutional or delegate side (Punia et al. 2025; Wu et al. 2022; Zhao & Su 2024), or it is appointed by the patient but evaluated only as a contingency path or as a key-custody threshold (Maruthi & Singh 2025; Tan, Chi & Lam 2024). Req 3 is the least satisfied requirement, graded Yes in 6 studies (Table 2.10). None of the papers examined makes approval by a patient-defined set a condition of every access decision.
- *Inability to bind purpose and data scope to the same decision as identity, authority and approval (Req 4):* Purpose and data-scope constraints are enforced by 10 of the 25 studies (Table 2.10), but in none of them are they bound to the same decision as identity, authority and multi-party approval; in the reviewed studies, multi-party approval is never conjoined with a purpose condition (Madine et al. 2020; Punia et al. 2025; Tan, Chi & Lam 2024). Without this binding, a valid identity and sufficient approvals can be used to obtain data outside the authorised scope.
- *Absence of temporal and lifecycle evaluation at the time of each access request (Req 5):* Req 5 is graded Yes in 8 of the 25 studies (Table 2.10). In these studies, the validity period, the lifecycle state and the revocation of a consent are enforced on a credential or at registration rather than evaluated when the request is made. Without such evaluation, a consent that has expired or been revoked remains usable once its approvals have been recorded.
- *Absence of formal and empirical assurance of the complete decision (Req 6):* Within Req 6, formal assurance is provided by 4 studies, argued informally by 9, and absent in the rest (Section 2.4.6). The studies that coordinate several mechanisms in one decision (Ferreira et al. 2025; Panagoulias et al. 2026; Phuyal et al. 2026b; Punia et al. 2025; Shanmugham & Senthilkumar 2026) test their own decisions, but none of them proves or tests a conjunction that includes multi-party approval, and any proof covers only a fragment of the predicate. Without such assurance, the correctness of the decision as a whole rests on the correctness of its parts.

The review has limitations. A single search string and a single round of coding mean that a small number of relevant studies may have been missed.

In the next section, we present our proposed framework to address the gaps.

2.5 Trust-Oriented Multi-Party Consent Authorisation Framework

The research addresses this gap by developing a trust-oriented authorisation model in which consent is not simply evidence that permission was granted, but the basis for evaluating whether a particular access request should be trusted. The resulting research direction places Trust Computing at the centre of the investigation, while treating blockchain, decentralised identity, verifiable credentials, and policy mechanisms as

enabling technologies supporting the broader trust model. Sections 2.5.1 to 2.5.6 state how the proposed framework, implemented in the HALAH prototype, addresses each requirement and the research objective that delivers it.

2.5.1 Representation of Consent as an Evaluable Authorisation Object (Req 1)

Consent is represented as the evaluable object C = (I, A, P, T, L, E), created through Algorithm 1 and evaluated at every access request. This requirement is delivered by RO1, presented in Chapter 5.

2.5.2 Decentralised Verification of Identity and Authority (Req 2)

DID and VC verification separates identity from authority and is evaluated as VI through Algorithm 2. The prototype checks the DID format, verifies each guardian's credential before the signature is added, and verifies the requesting doctor's credential at every access request. Full DID resolution is planned for the next stage. This requirement is delivered by RO2, presented in Chapter 6.

2.5.3 Multi-Party Authorisation through a Verifiable Threshold (Req 3)

N-of-N approval by the guardian set G with EIP-712 guardian signatures (Bloemen, Logvinov & Evans 2017), evaluated as VA through Algorithm 3. This requirement is delivered by RO3, presented in Chapter 7.

2.5.4 Policy- and Context-Aware Enforcement at the Time of Access (Req 4)

Purpose and a non-empty data scope within the consent are evaluated as VP through Algorithm 4. This requirement is delivered by RO4, presented in Chapter 8.

2.5.5 Temporal Validity and Lifecycle Control of Consent (Req 5)

The validity window VT, revocation, the lifecycle states, and the on-chain revocation on Sepolia are implemented, as specified in Algorithm 5. The SUSPENDED state and the lifecycle transition check are not yet implemented. This requirement is delivered by RO5, presented in Chapter 9.

2.5.6 Verifiable Auditability and Security Assurance (Req 6)

Audit ledger evidence and 46 automated tests, including twelve attack scenarios A1 to A12. The testing part of Algorithm 6 is done. Formal analysis is left for the next stage. This requirement is delivered by RO6, presented in Chapter 10.

2.6 Conclusion

This chapter reviewed the literature on multi-party consent and trustworthy data sharing in healthcare. Six requirements were stated for a trustworthy multi-party consent authorisation: an evaluable consent object, decentralised verification of identity and authority, multi-party authorisation through a verifiable threshold, policy- and context-aware enforcement at the time of access, temporal validity and lifecycle control, and verifiable auditability and security assurance. The literature was searched in seven databases, screened under the PRISMA 2020 statement, and evaluated against six quality questions, and 25 primary studies were analysed in full against the requirements.

The review shows that each requirement is met by some of the studies, but that no study meets them together. Multi-party approval, where it appears, is a contingency path, an admission gate or a registration-time co-consent, not a standing condition of every access decision with an approving set defined by the patient. Purpose and data scope are rarely

bound to the same decision as identity, authority and approval, and temporal validity and revocation are usually enforced on a credential rather than at the time of each request. Where several conditions are combined, the combined decision is neither proved nor systematically tested. These findings form the conjunction gap and the assurance gap. The next chapter states these gaps, the research questions that follow from them, and the objectives of this thesis.